ModSecurity Policy Adjustment for SQLi and XSS Mitigation

By. Sravan Kumar Mandeti

Introduction: This document presents a complete end-to-end implementation of ModSecurity with OWASP Core Rule Set (CRS) for detecting and mitigating SQL Injection (SQLi) and Cross-Site Scripting (XSS) attacks. The report documents every step performed during the lab, including configuration decisions, errors encountered, clarifications requested, and resolutions provided.

Objectives - Install and configure Apache with ModSecurity - Enable OWASP CRS - Test SQLi and XSS payloads using OWASP ZAP - Observe 403 Forbidden responses as evidence of payload blocking - Analyze ModSecurity audit logs - Identify false positives - Tune ModSecurity rules - Re-test after tuning and validate results.

Environment Setup Virtualization: QEMU with KVM Operating System: Ubuntu (latest) Web Server: Apache 2 WAF: ModSecurity v3 Rule Set: OWASP CRS (Debian package method) Attack Tool: OWASP ZAP Test Application: Apache-hosted PHP page.

QEMU + KVM Installation and Ubuntu VM Setup (WSL2)

First of all, Install WSL and Set Version to WSL2

wsl –install

wsl --set-default-version 2

Open WSL (Ubuntu) and Update Packages

sudo apt update && sudo apt upgrade -y

then Install QEMU, KVM, and Required Packages:

sudo apt install qemu-kvm libvirt-daemon-system libvirt-clients bridge-utils -y

after that Enable and Start libvirt Service:

sudo systemctl enable libvirtd

sudo systemctl start libvirtd

now, Add User to KVM Group

sudo usermod -aG kvm $USER

sudo usermod -aG libvirt $USER

after that Log out and log in again (or restart WSL) for group changes to apply.

Then after need to be #**wsl –shutdown** in terminal.

Create a Virtual Disk Image

qemu-img create -f qcow2 ubuntu.qcow2 30G #for creating an image of vm

Install Ubuntu Using ISO in QEMU

qemu-system-x86_64 \ -accel kvm \ -m 3 \ -smp 2 \ -vga virtio \ -drive file=ubuntu.qcow2,format=qcow2 -cdrom /mnt/c/Users/srava/Downloads/ubuntu.iso -boot d

for each sys configuration they need to setup the ram size manulally

#for ref check the install process link: https://youtu.be/dPg8P5DYZNg?si=MH_86roZsM7B8XKp

here after mount you need to give the path of your iso file of the latest version from the ubuntu website after downloading it, copy the path and make changes carefully (/, “, capital C will be there it should be small c)

enter the command in terminal qemu will ope, do some setups, and then in the end it will says remove the installing media, again you need to do is same the above command without the mnt

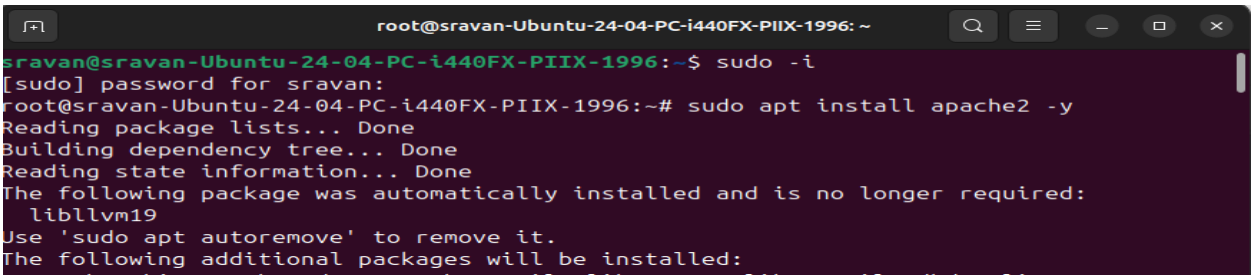
qemu-system-x86_64 \ -accel kvm \ -m 4096 \ -smp 4 \ -vga virtio \ -drive file=ubuntu.qcow2,format=qcow2

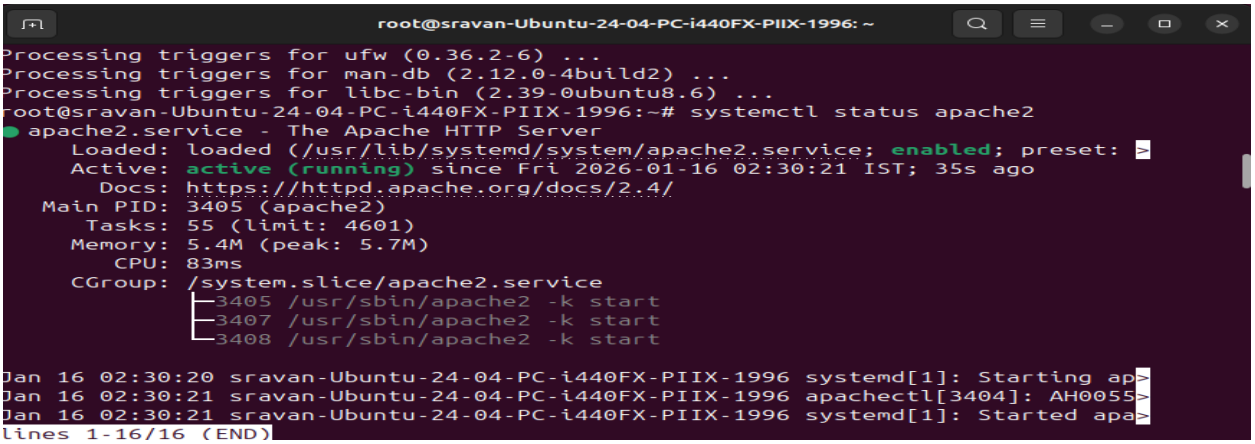
then after your qemu will be open successfully check the below image.

Then after QEMU will be opened and then open the terminal, here we can also do it local terminal or else in root, I tried with root.

Note: here if we try in root, we do get some restriction/ few privileges will be zone

Apache Installation





ModSecurity Installation

```
root@sravan-Ubuntu-24-04-PC-i440FX-PIIX-1996: ~
~
~
~
~
~
lines 1-16/16 (END)
[1]+  Stopped                 systemctl status aexit
logout
There are stopped jobs.
root@sravan-Ubuntu-24-04-PC-i440FX-PIIX-1996:~# sudo apt install libapache2-mod-security2 -y
Reading package lists... Done
Building dependency tree... Done
Reading state information... Done
The following package was automatically installed and is no longer required:
  libllvm19
Use 'sudo apt autoremove' to remove it.
The following additional packages will be installed:
  liblua5.1-0 libyajl2 modsecurity-crs
Suggested packages:
  lua geoip-database-contrib ruby python
The following NEW packages will be installed:
```

```
root@sravan-Ubuntu-24-04-PC-i440FX-PIIX-1996:~# apachectl -M | grep security
AH00558: apache2: Could not reliably determine the server's fully qualified domain name, using 127.0.1.1.
 Set the 'ServerName' directive globally to suppress this message
 security2_module (shared)
root@sravan-Ubuntu-24-04-PC-i440FX-PIIX-1996:~#
```

Here in the above, there was a one more feature is missing so, i did the same thing modsecurity installation with the #modsecurity3 and one more need update the #sudo apt update follow below:

```
root@sravan-Ubuntu-24-04-PC-i440FX-PIIX-1996:~# sudo apt update
Hit:1 http://in.archive.ubuntu.com/ubuntu noble InRelease
Hit:2 http://in.archive.ubuntu.com/ubuntu noble-updates InRelease
Hit:3 http://in.archive.ubuntu.com/ubuntu noble-backports InRelease
Hit:4 http://security.ubuntu.com/ubuntu noble-security InRelease
Reading package lists... Done
Building dependency tree... Done
Reading state information... Done
All packages are up to date.
```

ModSecurity was installed as an Apache module.

```
root@sravan-Ubuntu-24-04-PC-i440FX-PIIX-1996:~# sudo apt install libapache2-mod-security2 libmodsecurity3
 -y
Reading package lists... Done
Building dependency tree... Done
Reading state information... Done
Note, selecting 'libmodsecurity3t64' instead of 'libmodsecurity3'
libapache2-mod-security2 is already the newest version (2.9.7-1build3).
The following package was automatically installed and is no longer required:
  libllvm19
Use 'sudo apt autoremove' to remove it.
The following additional packages will be installed:
  geoip-database libfuzzy2 libgeoip1t64 liblua5.3-0
Suggested packages:
  geoip-bin
The following NEW packages will be installed:
```

Download OWASP ModSecurity Core Rule Set (CRS)

```
root@sravan-Ubuntu-24-04-PC-i440FX-PIIX-1996:/etc/modsecurity# sudo git clone https://github.com/coreruleset/coreruleset.git
Cloning into 'coreruleset'...
remote: Enumerating objects: 41623, done.
remote: Counting objects: 100% (210/210), done.
remote: Compressing objects: 100% (121/121), done.
remote: Total 41623 (delta 147), reused 133 (delta 89), pack-reused 41413 (from 4)
Receiving objects: 100% (41623/41623), 11.86 MiB | 3.96 MiB/s, done.
Resolving deltas: 100% (31706/31706), done.
root@sravan-Ubuntu-24-04-PC-i440FX-PIIX-1996:/etc/modsecurity# sudo mv coreruleset crs
root@sravan-Ubuntu-24-04-PC-i440FX-PIIX-1996:/etc/modsecurity# sudo cp crs/crs-setup.conf.example crs/crs-setup.conf
cp: cannot stat 'crs/crs-setup.conf.example': No such file or directory
root@sravan-Ubuntu-24-04-PC-i440FX-PIIX-1996:/etc/modsecurity# ls
crs  modsecurity.conf  modsecurity.conf-recommended  unicode.mapping
root@sravan-Ubuntu-24-04-PC-i440FX-PIIX-1996:/etc/modsecurity# ls /etc/modsecurity/crs
coreruleset     REQUEST-900-EXCLUSION-RULES-BEFORE-CRS.conf
crs-setup.conf  RESPONSE-999-EXCLUSION-RULES-AFTER-CRS.conf
root@sravan-Ubuntu-24-04-PC-i440FX-PIIX-1996:/etc/modsecurity# sudo systemctl restart apache2
root@sravan-Ubuntu-24-04-PC-i440FX-PIIX-1996:/etc/modsecurity# grep -i "crs" /var/log/apache2/error.log | tail
root@sravan-Ubuntu-24-04-PC-i440FX-PIIX-1996:/etc/modsecurity# sudo tail -n 30 /var/log/apache2/modsec_audit.log
<html><head>
<title>403 Forbidden</title>
</head><body>
<h1>Forbidden</h1>
<p>You don't have permission to access this resource.</p>
<hr>
<address>Apache/2.4.58 (Ubuntu) Server at localhost Port 80</address>
</body></html>

--2038dd1a-H--
```

Trigger an Attack (XSS)

to trigger the attack of xss, used the command as manually http://localhost/test.php?name=<script>alert(1)</script> # This **forces CRS to log**.

Now Enable Blocking Mode with this command below

```
root@sravan-Ubuntu-24-04-PC-i440FX-PIIX-1996:~# sudo nano /etc/modsecurity/modsecurity.conf
root@sravan-Ubuntu-24-04-PC-i440FX-PIIX-1996:~# sudo nano /etc/modsecurity/modsecurity.conf
```

here in this section, we need to edit this #SecRuleEngine On you need to change it to 'On', by default it will be like DetectionOnly, check below image:

```
root@sravan-Ubuntu-24-04-PC-i440FX-PIIX-1996: ~
  GNU nano 7.2                    /etc/modsecurity/modsecurity.conf
# -- Rule engine initialization ----------------------------------------------

# Enable ModSecurity, attaching it to every transaction. Use detection
# only to start with, because that minimises the chances of post-installation
# disruption.
#
SecRuleEngine DetectionOnly


# -- Request body handling ---------------------------------------------------

# Allow ModSecurity to access request bodies. If you don't, ModSecurity
# won't be able to see any POST parameters, which opens a large security
# hole for attackers to exploit.
#
SecRequestBodyAccess On


# Enable XML request body parser.
# Initiate XML Processor in case of xml content-type

^G Help      ^O Write Out  ^W Where Is   ^K Cut       ^T Execute    ^C Location   M-U Undo
^X Exit      ^R Read File  ^\ Replace    ^U Paste     ^J Justify    ^/ Go To Line M-E Redo
```

```
root@sravan-Ubuntu-24-04-PC-i440FX-PIIX-1996: ~
  GNU nano 7.2                    /etc/modsecurity/modsecurity.conf *
# -- Rule engine initialization ----------------------------------------------

# Enable ModSecurity, attaching it to every transaction. Use detection
# only to start with, because that minimises the chances of post-installation
# disruption.
#
SecRuleEngine On
```

after Save and Exit from it if any doubt re-check again with the previous command. Next Restart apache2: follow command below

```
root@sravan-Ubuntu-24-04-PC-i440FX-PIIX-1996:~# sudo nano /etc/modsecurity/modsecuri
ty.conf
root@sravan-Ubuntu-24-04-PC-i440FX-PIIX-1996:~# sudo systemctl restart apache2
```

Then after we need to check the modsecurity is loaded or not for that follow below commands. In the end you will be seen the #security2_model (shared):

```
root@sravan-Ubuntu-24-04-PC-i440FX-PIIX-1996:~# sudo systemctl restart apache2
root@sravan-Ubuntu-24-04-PC-i440FX-PIIX-1996:~# apachectl -M | grep security
AH00558: apache2: Could not reliably determine the server's fully qualified domain name, using 127.0.1.1.
 Set the 'ServerName' directive globally to suppress this message
 security2_module (shared)
root@sravan-Ubuntu-24-04-PC-i440FX-PIIX-1996:~#
```

Enable OWASP CRS

OWASP CRS was enabled using Debian package method. Follow below command so that next screen shot will be shown,

sudo nano /etc/apache2/mods-enabled/security2.conf

```
GNU nano 7.2
fModule security2_module>
      # Default Debian dir for modsecurity's persistent data
      SecDataDir /var/cache/modsecurity

      # Include all the *.conf files in /etc/modsecurity.
      # Keeping your local configuration in that directory
      # will allow for an easy upgrade of THIS file and
      # make your life easier
      IncludeOptional /etc/modsecurity/*.conf

      # Include OWASP ModSecurity CRS rules if installed
      IncludeOptional /usr/share/modsecurity-crs/*.load
IfModule>
```

Apache Config Validation

```
root@sravan-Ubuntu-24-04-PC-i440FX-PIIX-1996:/home/sravan# sudo nano /etc/apache2/mods-enabled/security2.conf
root@sravan-Ubuntu-24-04-PC-i440FX-PIIX-1996:/home/sravan# sudo apachectl configtest
AH00558: apache2: Could not reliably determine the server's fully qualified domain name, using 127.0.1.1. Set the 'ServerName' directive globally to suppress this message
Syntax OK
root@sravan-Ubuntu-24-04-PC-i440FX-PIIX-1996:/home/sravan#
```

Test Web Application

Install the php

```
root@sravan-Ubuntu-24-04-PC-i440FX-PIIX-1996:/home/sravan# sudo apt install php -y
Reading package lists... Done
Building dependency tree... Done
Reading state information... Done
The following package was automatically installed and is no longer required:
  libllvm19
Use 'sudo apt autoremove' to remove it.
The following additional packages will be installed:
  libapache2-mod-php8.3 php-common php8.3 php8.3-cli php8.3-common php8.3-opcache php8.3-readline
Suggested packages:
  php-pear
The following NEW packages will be installed:
  libapache2-mod-php8.3 php php-common php8.3 php8.3-cli php8.3-common php8.3-opcache php8.3-readline
0 upgraded, 8 newly installed, 0 to remove and 0 not upgraded.
Need to get 4,918 kB of archives.
After this operation, 22.4 MB of additional disk space will be used.
Get:1 http://in.archive.ubuntu.com/ubuntu noble/main amd64 php-common all 2:93ubuntu2 [13.9 kB]
Get:2 http://in.archive.ubuntu.com/ubuntu noble-updates/main amd64 php8.3-common amd64 8.3.6-0ubuntu0.24.04.6 [740 kB]
Get:3 http://in.archive.ubuntu.com/ubuntu noble-updates/main amd64 php8.3-opcache amd64 8.3.6-0ubuntu0.24.04.6 [372 kB]
Get:4 http://in.archive.ubuntu.com/ubuntu noble-updates/main amd64 php8.3-readline amd64 8.3.6-0ubuntu0.24.04.6 [13.4 kB]
Get:5 http://in.archive.ubuntu.com/ubuntu noble-updates/main amd64 php8.3-cli amd64 8.3.6-0ubuntu0.24.04.6 [1,916 kB]
Get:6 http://in.archive.ubuntu.com/ubuntu noble-updates/main amd64 libapache2-mod-php8.3 amd64 8.3.6-0ubuntu0.24.04.6 [1,850 kB]
Get:7 http://in.archive.ubuntu.com/ubuntu noble-updates/main amd64 php8.3 all 8.3.6-0ubuntu0.24.04.6 [9,172 B]
Get:8 http://in.archive.ubuntu.com/ubuntu noble/main amd64 php all 2:8.3+93ubuntu2 [4,076 B]
Fetched 4,918 kB in 3s (1,821 kB/s)
Selecting previously unselected package php-common.
```

```
root@sravan-Ubuntu-24-04-PC-i440FX-PIIX-1996:/home/sravan# sudo nano /var/www/html/test.php
root@sravan-Ubuntu-24-04-PC-i440FX-PIIX-1996:/home/sravan# sudo systemctl restart apache2
root@sravan-Ubuntu-24-04-PC-i440FX-PIIX-1996:/home/sravan# sudo tail -f /var/log/apache2/modsec_audit.log
Apache-Handler: application/x-httpd-php
Stopwatch: 1768530158443820 12947 (- - -)
Stopwatch2: 1768530158443820 12947; combined=9146, p1=2058, p2=6833, p3=0, p4=0, p5=255, sr=191, sw=0, l=0, gc=0
Response-Body-Transformed: Dechunked
Producer: ModSecurity for Apache/2.9.7 (http://www.modsecurity.org/); OWASP_CRS/3.3.5.
Server: Apache/2.4.58 (Ubuntu)
Engine-Mode: "ENABLED"

--c779250e-Z--
```

In the nano command write the small code for the php test check below

<?php

$name = $_GET['name'];

echo "Hello " . $name;

?>

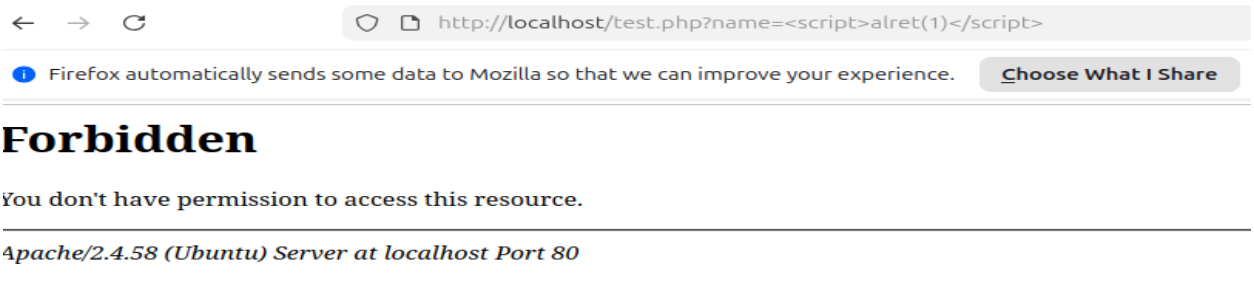
After entring it, Save and Exit

then Restart the apache2 check in the above image.

<u>Manual XSS Attack Test(Payload)</u>

Open browser and visit:

http://localhost/test.php?name=<script>alert(1)</script>



<u>Checking ModSecurity Logs</u>

Enter the below command in the terminal you will get the logs with Rule Id's:

sudo tail -f /var/log/apache2/modsec_audit.log

Note: check carefully you will find the id with XSS AttackDetected:

For me I found 4 Unique ids, for ref one image was added. # This **forces CRS to log**.

```
_score. [file "/usr/share/modsecurity-crs/rules/REQUEST-949-BLOCKING-EVALUATION.conf"] [line "94"] [id "949110"] [msg "Inbound Anomaly Score Exceeded (Total Score: 15)"] [severity "CRITICAL"] [ver "OWASP_CR

are/modsecurity-crs/rules/RESPONSE-980-CORRELATION.conf"] [line "92"] [id "980130"] [msg "Inbound Anomaly Score Exceeded (Total Inbound Score: 15 - SQLI=0,XSS=15,RFI=0,LFI=0,RCE=0,PHPI=0,HTTP=0,SESS=0): ind

curity: Warning. detected XSS using libinjection. [file "/usr/share/modsecurity-crs/rules/REQUEST-941-APPLICATION-ATTACK-XSS.conf"] [line "56"] [id "941100"] [msg "XSS Attack Detected via libinjection"] [da
r "OWASP_CRS/3.3.5"] [tag "application-multi"] [tag "language-multi"] [tag "platform-multi"] [tag "attack-xss"] [tag "paranoia-level/1"] [tag "OWASP_CRS"] [tag "capec/1000/152/242"] [hostname "localhost"] [

curity: Warning. Pattern match "(?i)<script[^>]*>[\\\\\\\\s\\\\\\\\S]*?" at ARGS:name. [file "/usr/share/modsecurity-crs/rules/REQUEST-941-APPLICATION-ATTACK-XSS.conf"] [line "83"] [id "941110"] [msg "XSS F
ret(1)</script>"] [severity "CRITICAL"] [ver "OWASP_CRS/3.3.5"] [tag "application-multi"] [tag "language-multi"] [tag "platform-multi"] [tag "attack-xss"] [tag "paranoia-level/1"] [tag "OWASP_CRS"] [tag "ca
```

OWASP ZAP Installation

Here we required java also for running the OWASP ZAP, for the installation use these commands below:

sudo apt install openjdk-17-jre -y

java -version

for ZAP instead of download directly form browser, I used to install from the terminal only here the commands below:

1st - sudo apt install zaproxy -y or 2nd - sudo snap install zaproxy –classic

After enter these commands:

which zaproxy

/snap/bin/zaproxy --version

I used 2nd one, instead of 1st, here 1st is installed but having issues when running the task so I killed the installation with the command below: so that I tried with the 2nd one.

ZAP Troubleshooting

pkill -9 -f zap

pkill -9 -f java

and also, small updates with ZAP commands are:

ps aux | grep zap #checks nothing is running

zaproxy -daemon -host 127.0.0.1 -port 8080 -lowmem #when ZAP got struck so need reduce the memory size with this command

After successfully running the 2nd command ZAP will be Opened #command **zaproxy**

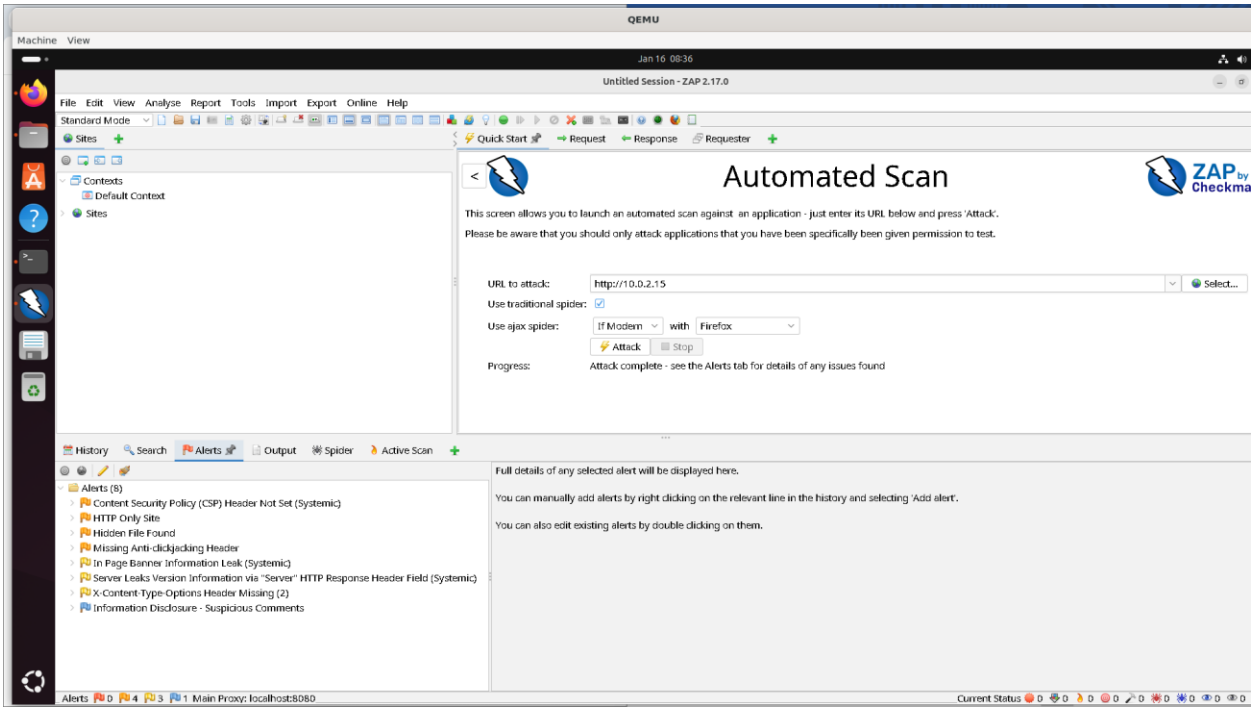
```
root@sravan-Ubuntu-24-04-PC-i440FX-PIIX-1996:/home/sravan# sudo snap install zaproxy --classic
snap "zaproxy" is already installed, see 'snap help refresh'
root@sravan-Ubuntu-24-04-PC-i440FX-PIIX-1996:/home/sravan# zaproxy
mkdir: missing operand
Try 'mkdir --help' for more information.
g_module_open() failed for /snap/zaproxy/54/usr/lib/x86_64-linux-gnu/gdk-pixbuf-2.0/2.10.0/loaders/li
found Java version 17.0.17
available memory: 3916 MB
```

Next, need to do check for you ip address to identify our ip just give # **ip a** ** this for ubuntu

Then go for attacking with the host ip address this will gives us a report. Here is the command below:

http://10.0.2.15 #for each and every system has unique ip check with your ip addresses

now get into the ZAP interface open you will find the automated scan in the screen there you need to enter #your IP Address, and then not touch anything directly click on the attack. It will take second to finsh the task and then gives the alret report in the below section, you can see in the image below:



Observing ZAP Results (Before Tuning)

- **Alerts tab**

You saw:

- Informational / header issues
- No SQLi / XSS vulnerabilities

Meaning:
Payloads were sent but **blocked by ModSecurity**.

Correlate With ModSecurity Logs

sudo tail -n 100 /var/log/apache2/modsec_audit.log

we observe the

- HTTP **403 Forbidden**
- Multiple **XSS rule IDs**
- Repeated rule **920350**
- **File is not found**

This log data belongs to **BEFORE TUNING**

For the BEFORE TUNING REOPRT the command is followed below:

```
root@sravan-Ubuntu-24-04-PC-i440FX-PIIX-1996:/etc/modsecurity# zaproxy -cmd -quickurl http://10.0.2.15 -quickout /home/sravan/zap_before_tuning.html
mkdir: missing operand
Try 'mkdir --help' for more information.
g_module_open() failed for /snap/zaproxy/54/usr/lib/x86_64-linux-gnu/gdk-pixbuf-2.0/2.10.0/loaders/libpixbufloader-tiff.so: libtiff.so.5: cannot open shared object file: No such file or directory
Found Java version 17.0.17
Available memory: 3916 MB
Using JVM args: -Xmx979m
Writing results to /home/sravan/zap_before_tuning.html
```

The given location of the file name the report it will send to our file manager there we can check the report but it is unreadable.

To know the what permissions it consists of we will see with the command below:

```
root@sravan-Ubuntu-24-04-PC-i440FX-PIIX-1996:/home/sravan# ls -l /home/sravan/zap_before_tuning.html
-rw-r--r-- 1 root root 57923 Jan 16 05:43 /home/sravan/zap_before_tuning.html
```

MODSECURITY RULE TUNING

False Positive Detection

Identify Noisy / Blocking Rules

```
root@sravan-Ubuntu-24-04-PC-i440FX-PIIX-1996:/home/sravan# sudo tail -n 100 /var/log/apache2/modsec_audit.log

--bbe66e7f-E--
<!DOCTYPE HTML PUBLIC "-//IETF//DTD HTML 2.0//EN">
<html><head>
<title>404 Not Found</title>
</head><body>
<h1>Not Found</h1>
<p>The requested URL was not found on this server.</p>
<hr>
<address>Apache/2.4.58 (Ubuntu) Server at 10.0.2.15 Port 80</address>
</body></html>

--bbe66e7f-H--
Message: Warning. Pattern match "^[\\d.:]+$" at REQUEST_HEADERS:host. [file "/usr/share/modsecurity-crs/rules/REQUEST-920-PROTOCOL-ENFORCEMENT.conf"] [line "736"] [id "920350"] [msg "Host header is a numeric IP address"]
```

AFTER-TUNING STEP-BY-STEP PROCESS

Confirm the False Positive (Before Touching Anything)

already identified: from the above image

- Rule ID: **920350**
- Reason: Host header numeric IP
- Severity: WARNING
- Repeated in logs
- Triggered due to lab IP (10.0.2.15)

Command used:

sudo tail -n 100 /var/log/apache2/modsec_audit.log

Create a Custom Tuning File

here We never edit CRS rules directly. Here is the command

sudo nano /etc/modsecurity/custom_rules.conf **#** we need to add the rules custom and include

```
GNU nano 7.2
ecRuleRemoveById 920350

nclude /etc/modsecurity/custom_rules.conf
```

Now Validate Apache Configuration command is

sudo apachectl configtest

```
root@sravan-Ubuntu-24-04-PC-i440FX-PIIX-1996:/home/sravan# sudo rm /etc/modsecurity/custom_rules.conf
root@sravan-Ubuntu-24-04-PC-i440FX-PIIX-1996:/home/sravan# sudo apachectl configtest
AH00558: apache2: Could not reliably determine the server's fully qualified domain name, using 127.0.1.1. Set the 'ServerName' directive globally to suppress this message
Syntax OK
root@sravan-Ubuntu-24-04-PC-i440FX-PIIX-1996:/home/sravan# sudo systemctl restart apache2
root@sravan-Ubuntu-24-04-PC-i440FX-PIIX-1996:/home/sravan# sudo tail -n 50 /var/log/apache2/modsec_audit.log
--3eb25803-H--
```

Note: tail -n 50 and tail -n 100 are showing OLD log entries, not new ones.

That is why:

- tail -n 50 → shows **2 entries**
- tail -n 100 → shows **3 entries**
- All with the **same rule ID (920350)**

Finally, the before tuning ids which are not appeared again compare to the after tuning configuration test. here a small comparison table.

Parameter	**Before Tuning**	**After Tuning**
Rule 941100 and other	Triggered	Not triggered
XSS detection	Active	Active
SQLi detection	Active	Active
HTTP status	403	403
ZAP alerts	Informational	Informational

<u>Conclusion</u>

ModSecurity was successfully configured with the OWASP Core Rule Set on an Apache web server to protect a test web application from SQL Injection and Cross-Site Scripting attacks. Manual payload testing and automated OWASP ZAP scans confirmed that malicious requests were detected and blocked with HTTP 403 responses. A protocol-related false positive (rule ID 920350) identified during log analysis was safely tuned using a CRS exclusion rule without modifying core rules. Post-tuning validation and re-scanning verified that false positives were reduced while XSS and SQLi protections remained fully effective.